Care Access Navigator

CloudSec1 Rubric — Criterion 5: Cloud Compliance & Governance Controls

Evidence Package — HIPAA Compliance Checklist & Gap Analysis, Management-Group Governance, Deny Guardrails, Mandatory Tagging and Automated Compliance Checking

Prepared by:	Akhila Chennamaneni
Capstone:	Care Access Navigator (HealthLine Regional Medical Center)
Rubric criterion:	Criterion 5 — Cloud Compliance & Governance Controls (CloudSec1)
Environment:	Microsoft Azure — tenant chakhilaraogmail.onmicrosoft.com, Azure subscription 1; Azure Policy, Management Groups, Defender for Cloud (free tier)
Framework:	HIPAA Security Rule (45 CFR §164.308–§164.312), via the built-in HITRUST/HIPAA initiative; NIST CSF 2.0 crosswalk
Evidence date:	October 8, 2026

Objective

This criterion requires mapping cloud configurations to a major compliance framework — with a checklist, gap analysis and remediation plan — and implementing governance: an organisation hierarchy with preventive policies, mandatory resource tagging, and automated compliance checking with documented evidence that the policies are enforced. CAN handles electronic health records, so **HIPAA** was chosen as the framework.

Platform equivalents

The rubric names AWS services. CAN is built on Microsoft Azure, so each control was implemented with its native Azure equivalent:

AWS (rubric)	Azure implementation in CAN
AWS Organizations (OUs)	Management groups (mg-can → workloads / sandbox)
Service Control Policies	Azure Policy assignments with Deny effect at management-group scope
Tag policies / mandatory tagging	Azure Policy 'Require a tag' (Deny) on resources and resource groups
AWS Config Rules + conformance pack	Azure Policy compliance evaluation + built-in HITRUST/HIPAA initiative
Config compliance dashboard	Azure Policy compliance view / Defender for Cloud regulatory compliance

Cost: Every governance control in this package uses free Azure features (Management Groups, Azure Policy, Defender for Cloud foundational CSPM). All enforcement tests either failed before creation or used validate-only deployments, so testing created no billable resources.

Results at a Glance

Requirement	Implementation	Verified result
Compliance framework mapping	HIPAA Security Rule checklist — 22 controls mapped to CAN's real configuration, with NIST CSF 2.0 crosswalk	7 Met · 8 Partial · 7 Gap
Gap analysis & remediation plan	13 prioritised actions with owner, target date and cost	1 completed (tagging); remainder scheduled
Organisation hierarchy (AWS Organizations)	mg-can → mg-can-workloads (subscription) / mg-can-sandbox	**PASS** — subscription moved under governed hierarchy
Preventive policies (SCPs)	7 Deny rules in one initiative at mg-can	**PASS** — 7 of 7 guardrail violations blocked
Mandatory tagging	Owner, Environment, DataClassification required (Deny) on resources and RGs	**PASS** — untagged resource and RG blocked; 24/24 assets remediated
Automated compliance checking (Config Rules)	HITRUST/HIPAA initiative (586 controls, 90 automated) assigned audit-only; on-demand scans	**PASS** — continuous evaluation; tags 0 → 72 compliant

Part A — Governance Hierarchy (AWS Organizations equivalent)

Azure **management groups** sit above subscriptions the way AWS Organizations OUs sit above accounts. Policies assigned to a management group are inherited by every subscription, resource group and resource beneath it and cannot be removed by a subscription owner — the same property that makes SCPs effective. CAN's production-style subscription was moved under a dedicated HIPAA workloads group, with a separate sandbox group that inherits only the organisation guardrails.

Management groups and policy assignments

```
== Management group hierarchy (AWS Organizations equivalent)
Tenant Root Group
+-- mg-can               Care Access Navigator           <- guardrails (Deny)
    +-- mg-can-workloads CAN Workloads (HIPAA)           <- mandatory tags (Deny) + HITRUST/HIPAA
     audit
    |   +-- subscription: Azure subscription 1 (9a8c964b-cf59-4657-bff2-5f84fb7b0709)
    +-- mg-can-sandbox   CAN Sandbox                     <- guardrails only (inherited)

== Policy assignments
mg-can             CAN - Organization guardrails (SCP equivalent)      enforcement=Default
mg-can-workloads   CAN - Mandatory resource tags                       enforcement=Default
mg-can-workloads   CAN - HITRUST/HIPAA compliance audit                enforcement=DoNotEnforce
```

STEP B1 Service Control Policy equivalents — organisation guardrails

Seven built-in Azure Policy definitions were combined into one custom initiative, **CAN – Organization guardrails (SCP equivalent)**, assigned at the top of the hierarchy (`mg-can`) with the **Deny** effect. Like an SCP, a Deny policy stops the request at the Azure Resource Manager control plane before anything is created, regardless of the caller's RBAC role — even a subscription Owner is blocked.

Rule (reference ID)	Built-in policy	Parameter	Purpose
allowed-locations	Allowed locations	eastus, northcentralus	Data residency in approved US regions; limits sprawl
allowed-rg-locations	Allowed locations for resource groups	eastus, northcentralus	Resource-group metadata stays in approved regions
denied-resource-types	Not allowed resource types	bastionHosts, azureFirewalls, applicationGateways, expressRouteCircuits, managedClusters (AKS)	Blocks high-cost services without approval (cost governance)
allowed-vm-skus	Allowed virtual machine size SKUs	B1s, B1ms, B2s, B2ats_v2, F1als_v7, F1as_v7	Only small, approved VM sizes
storage-no-public-access	Storage account public access should be disallowed	Deny	No anonymous blob access to PHI
storage-secure-transfer	Secure transfer to storage accounts should be enabled	Deny	HTTPS only for data in transit
storage-min-tls12	Storage accounts should have the specified minimum TLS version	Deny, TLS1_2	Blocks legacy TLS 1.0/1.1

A custom non-compliance message explains each denial to the user: *"Blocked by CAN guardrails: only eastus/northcentralus, approved small VM sizes, no public/insecure storage, and no high-cost network services are permitted."*

STEP C1 Mandatory resource tagging

The **CAN – Mandatory resource tags** initiative applies the built-in *Require a tag on resources* and *Require a tag on resource groups* policies once per tag (six rules), with the Deny effect, at `mg-can-workloads`. A resource that is missing any of the three tags cannot be created.

Tag	Purpose	Values
Owner	Accountable person (email-style alias)	akhila.chennamaneni
Environment	Lifecycle stage; drives guardrail strictness	Lab | Dev | Test | Prod
DataClassification	Highest sensitivity of data the resource can hold	Public | Internal | Confidential | PHI

Remediation of existing assets. Policies only block new or changed resources, so the first scan reported all 24 existing resources and resource groups as non-compliant. All 24 were then tagged; the

six resources that run or store the EHR workload were classified **Confidential**, network and platform resources **Internal**.

evidence/04-tag-remediation.txt

```
== Tag remediation 2026-10-08 19:30 UTC
RG       rg-cloudsec1-can  -> DataClassification=Internal
RG       NetworkWatcherRG  -> DataClassification=Internal
RG       DefaultResourceGroup-EUS  -> DataClassification=Internal
resource cloudsecevidencecan  -> DataClassification=Internal
resource public-sg  -> DataClassification=Internal
resource app-sg  -> DataClassification=Internal
resource data-sg  -> DataClassification=Internal
resource can-vnet-cloudsec1  -> DataClassification=Internal
resource NetworkWatcher_eastus  -> DataClassification=Internal
resource DefaultWorkspace-9a8c964b-cf59-4657-bff2-5f84fb7b0709-EUS  -> DataClassification=Internal
resource acrcloudseccan  -> DataClassification=Confidential
resource aci-app-test  -> DataClassification=Confidential
resource func-sg  -> DataClassification=Internal
resource id-can-func  -> DataClassification=Confidential
resource stcanfunc9a8c964b  -> DataClassification=Confidential
resource ASP-rgcloudsec1can-cc4f  -> DataClassification=Confidential
resource func-can-ehr-9a8c96  -> DataClassification=Confidential
resource vm-sg  -> DataClassification=Internal
resource can-vnet-vmlab  -> DataClassification=Internal
resource NetworkWatcher_northcentralus  -> DataClassification=Internal
resource can-vm-pip  -> DataClassification=Internal
resource can-vm-hardenedVMNic  -> DataClassification=Internal
resource can-vm-hardened  -> DataClassification=Internal
resource can-vm-hardened_OsDisk_1_ed979d1137ec42c192dbb8a13a2a26bf  -> DataClassification=Internal
```

STEP D1 Automated compliance checking (AWS Config Rules equivalent)

Microsoft's built-in **HITRUST/HIPAA** regulatory initiative (586 policy references across 576 control groups) was assigned to `mg-can-workloads`. Of its controls, 496 are *manual* attestations (policies, training, procedures) and 90 are automated checks that Azure re-evaluates continuously and on every resource change — the equivalent of an AWS Config conformance pack. Defender for Cloud's default *Microsoft cloud security benchmark* assignment (`SecurityCenterBuiltIn`) provides a second, independent assessment.

> **Design decision:** The initiative contains 6 policies that can deploy or modify resources (Guest Configuration extensions, IaaS antimalware, Network Watcher). It was therefore assigned with **enforcementMode = DoNotEnforce**: it evaluates and reports on all checks but never changes or deploys anything, so it cannot create unplanned cost. Enforcement is handled by the explicit Deny initiatives above.

The tagging remediation moved the mandatory-tags assignment from **0 compliant / 72 non-compliant** to **72 compliant / 0 non-compliant**. The HITRUST/HIPAA findings are unchanged because they need the planned remediations in Part G; they form the automated input to the gap analysis.

evidence/05-compliance-before-after.txt (latest result per rule)

```
== Azure Policy compliance, before vs after remediation
   (latest evaluation per resource/rule; C = compliant, NC = non-compliant, M = manual)

assignment              BEFORE (19:23 UTC)         AFTER (19:33 UTC)
can-guardrails          C 31   NC   0              C 31   NC   0
can-mandatory-tags      C  0   NC  72  (24 res.)   C 72   NC   0  (0 res.)
can-hipaa-hitrust       C 16   NC  35  (20 res.)   C 16   NC  35  (20 res.)   M 496
SecurityCenterBuiltIn   C 20   NC  48  (7 res.)    C 20   NC  48  (7 res.)
```

Part E — Evidence of Policy Enforcement

Each rule was tested in isolation: test requests carried the mandatory tags (so the tag rule could not mask other rules) and broke exactly one guardrail. A fully compliant request (T10) was included as a control to prove the policies block only what they should. Oversized-VM and Bastion tests used `az deployment group validate`, which runs the same policy check without creating anything.

Test	Request	Expected	Result
T1	NSG with no tags	Deny (tags)	**DENIED** — 3 tag rules
T2	Resource group with no tags	Deny (tags)	**DENIED** — 3 tag rules
T3	Tagged NSG in centralus	Deny (region)	**DENIED** — allowed-locations*
T4	Tagged RG in westus	Deny (region)	**DENIED** — allowed-rg-locations
T5	Storage with public blob access	Deny	**DENIED** — storage-no-public-access
T6	Storage allowing HTTP	Deny	**DENIED** — storage-secure-transfer
T7	Storage with TLS 1.0	Deny	**DENIED** — storage-min-tls12
T8	VM Standard_D16s_v5	Deny (size)	**DENIED** — allowed-vm-skus
T9	Azure Bastion host	Deny (type)	**DENIED** — denied-resource-types
T10	Compliant tagged NSG in eastus	Allow	**ALLOWED** — control (then deleted)

evidence/01-enforcement-tests.txt

```
== CAN governance enforcement tests  (2026-10-08 19:22 UTC, subscription under mg-can-workloads)
-- T1 resource with no tags
   $ az network nsg create -g rg-cloudsec1-can -n t1-untagged-nsg -l eastus
   DENIED  | assignment: CAN - Mandatory resource tags | rule:
    require-dataclassification-tag-resources, require-environment-tag-resources,
    require-owner-tag-resources
-- T2 resource group with no tags
   $ az group create -n rg-t2-untagged -l eastus
   DENIED  | assignment: CAN - Mandatory resource tags | rule: require-dataclassification-tag-rg,
    require-environment-tag-rg, require-owner-tag-rg
-- T3 tagged resource, region centralus
   $ az network nsg create -g rg-cloudsec1-can -n t3-centralus-nsg -l centralus --tags
    Owner=akhila.chennamaneni Environment=Lab DataClassification=Internal
   19:23 UTC  ALLOWED | created  <- inside the policy propagation window; NSG deleted immediately
   19:24 UTC  DENIED  | assignment: CAN - Organization guardrails (SCP equivalent) | rule:
    allowed-locations   (re-test after propagation)
-- T4 tagged RG, region westus
   $ az group create -n rg-t4-westus -l westus --tags Owner=akhila.chennamaneni Environment=Lab
    DataClassification=Internal
   DENIED  | assignment: CAN - Organization guardrails (SCP equivalent) | rule:
    allowed-rg-locations
-- T5 storage with public blob access
   $ az storage account create -g rg-cloudsec1-can -n stcant5pub$RANDOM -l eastus --sku
    Standard_LRS --allow-blob-public-access true --min-tls-version TLS1_2 --https-only true --tags
     Owner=akhila.chennamaneni Environment=Lab DataClassification=Internal
   DENIED  | assignment: CAN - Organization guardrails (SCP equivalent) | rule:
    storage-no-public-access
-- T6 storage allowing plain HTTP
   $ az storage account create -g rg-cloudsec1-can -n stcant6http$RANDOM -l eastus --sku
    Standard_LRS --allow-blob-public-access false --min-tls-version TLS1_2 --https-only false
    --tags Owner=akhila.chennamaneni Environment=Lab DataClassification=Internal
   DENIED  | assignment: CAN - Organization guardrails (SCP equivalent) | rule:
    storage-secure-transfer
-- T7 storage with TLS 1.0
   $ az storage account create -g rg-cloudsec1-can -n stcant7tls$RANDOM -l eastus --sku
    Standard_LRS --allow-blob-public-access false --min-tls-version TLS1_0 --https-only true
    --tags Owner=akhila.chennamaneni Environment=Lab DataClassification=Internal
   DENIED  | assignment: CAN - Organization guardrails (SCP equivalent) | rule: storage-min-tls12
-- T8 oversized VM (validate only)
   $ az deployment group validate -g rg-cloudsec1-can --template-file
    /Users/Adult/Desktop/dae_6mon_coh2_AC/can-governance/evidence/vm-oversize.json
   DENIED  | assignment: CAN - Organization guardrails (SCP equivalent) | rule: allowed-vm-skus
-- T9 Bastion host (validate only)
   $ az deployment group validate -g rg-cloudsec1-can --template-file
    /Users/Adult/Desktop/dae_6mon_coh2_AC/can-governance/evidence/bastion.json
   DENIED  | assignment: CAN - Organization guardrails (SCP equivalent) | rule:
    denied-resource-types
-- T10 CONTROL: compliant tagged NSG in eastus
   $ az network nsg create -g rg-cloudsec1-can -n t10-compliant-nsg -l eastus --tags
    Owner=akhila.chennamaneni Environment=Lab DataClassification=Internal
   ALLOWED | created
```

Issue encountered: *T3's first attempt, one minute after assignment, succeeded because Azure Policy assignments take up to ~30 minutes to propagate to every resource provider. The test NSG was deleted immediately; the repeat test after propagation was denied by allowed-locations. A West Europe attempt was also discarded because Azure itself refused the region (capacity), which is not evidence of our policy.

Part F — HIPAA Compliance Checklist

Each HIPAA Security Rule safeguard was mapped to how CAN is actually configured. Status was assigned from verified configuration and Azure Policy results: **Met** (control in place and evidenced), **Partial** (in place with a material weakness) or **Gap** (missing). The same checklist, with a NIST CSF 2.0 crosswalk, is provided as an Excel workbook.

ID	HIPAA ref.	Requirement	CAN configuration	Status
A1	§164.308(a)(1)(ii)(A)	Risk analysis	Cloud risk assessment workbook; Trivy image scanning; continuous Azure Policy HIPAA evaluation Evidence: Risk_Assessment.xlsx; Infra PDF Part B; policy scan	**Met**
A2	§164.308(a)(1)(ii)(B)	Risk management	Deny guardrails at management-group level (regions, VM sizes, storage baselines, banned resource types) Evidence: Enforcement tests T3–T9	**Met**
A3	§164.308(a)(1)(ii)(D)	Information system activity review	Activity Log kept 90 days by default only; no export to Log Analytics; no activity-log alerts Evidence: Policy: 'activity log alert should exist' NonCompliant; 0 subscription diagnostic settings	**Gap**
A4	§164.308(a)(3)(ii)(B)	Workforce clearance / least privilege	Entra app roles mapped to 7 Keycloak roles; function identity holds one scoped role Evidence: Criterion 4 addendum; Infra PDF Step C2	**Met**
A5	§164.308(a)(4)(ii)(B)	Access authorization (privileged access)	Single subscription Owner, and it is a guest (#EXT#) personal Microsoft account Evidence: Policy: guest owners / more than one owner NonCompliant	**Gap**
A6	§164.308(a)(5)(ii)(B)	Protection from malicious software	VM automatic patching (Azure + unattended-upgrades); container images 0 CVEs; no VM vulnerability scanner Evidence: Infra PDF Part A; policy: 'vulnerability assessment on VMs' NonCompliant	**Partial**
A7	§164.308(a)(5)(ii)(C)	Log-in monitoring	fail2ban + sshd VERBOSE on VM; Entra sign-in logs (Free tier, 7-day retention) Evidence: Infra PDF Step A4	**Partial**
A8	§164.308(a)(6)	Security incident procedures	No documented, tested incident-response playbook yet Evidence: Delivered by Criterion 6 (Security Operations & IR)	**Gap**
A9	§164.308(a)(7)(ii)(A)	Data backup plan	No Azure Backup vault; VM not backed up; blob soft-delete on evidence storage only Evidence: Policy: 'Azure Backup should be enabled for VMs' NonCompliant; 0 Recovery Services vaults	**Gap**
A10	§164.308(a)(7)(ii)(B)	Disaster recovery plan	No cross-region recovery configured (single-region lab) Evidence: Policy: 'VMs without disaster recovery' NonCompliant	**Gap**

ID	HIPAA ref.	Requirement	CAN configuration	Status
A11	§164.308(a)(8)	Evaluation	HITRUST/HIPAA initiative continuously evaluates 90 automated checks; on-demand scans Evidence: evidence/05-compliance-before-after.txt	**Met**
A12	§164.308(b)(1)	Business associate agreement	Microsoft HIPAA BAA applies to in-scope Azure services via the Product Terms Evidence: Inherited (shared responsibility)	**Met**
P1	§164.310(a)–(d)	Facility, workstation and device controls	Azure datacenter physical security (inherited); admin workstation is a shared lab Mac Evidence: Shared-responsibility model (Fundamentals PDF)	**Partial**
T1	§164.312(a)(2)(i)	Unique user identification	Entra users and per-person Keycloak federated usernames (entra-id.) Evidence: Criterion 4 addendum, defect 3 fix	**Met**
T2	§164.312(a)(2)(iv)	Encryption at rest	Storage and managed disks encrypted with platform-managed keys; no CMK or encryption-at-host Evidence: Storage keySource=Microsoft.Storage; VM encryptionAtHost=null	**Partial**
T3	§164.312(b)	Audit controls	No diagnostic settings on 12 resources (ACR, ACI, NSGs, VM, VNets, storage, function) Evidence: Policy: 'Audit diagnostic setting' NonCompliant (12 resources)	**Gap**
T4	§164.312(c)(1)	Integrity	Container base images pinned by digest; blob versioning on evidence storage; none on function storage Evidence: Infra PDF Step B2; blob service properties	**Partial**
T5	§164.312(d)	Person or entity authentication	SSH key-only; managed identities for workloads; Entra MFA (security defaults) not verifiable via CLI Evidence: Infra PDF A4/C2; MFA status to confirm in portal	**Partial**
T6	§164.312(e)(1)	Transmission security	TLS 1.2 minimum and HTTPS-only enforced by Deny policy; Keycloak lab endpoint is plain HTTP on localhost Evidence: Enforcement tests T6–T7	**Partial**
H1	§164.312(e)(1)	Network segregation	NSGs on all workload subnets; function VNet-integrated; but evidence storage and ACR accept all networks; VM SSH open to one IP without JIT Evidence: Policy: storage network access, ACR service endpoint, JIT NonCompliant	**Partial**
H2	§164.310(d)(2)(iii)	Asset inventory and ownership	Mandatory Owner / Environment / DataClassification tags enforced by Deny policy; all 24 assets tagged Evidence: Tag compliance 0 → 72 compliant	**Met**
H3	§164.308(a)(5)(ii)(D)	Credential management	Container registry admin (shared) credential still enabled; older storage account allows key access Evidence: ACR adminUserEnabled=true; cloudsecevidencecan allowSharedKeyAccess=true	**Gap**

Part G — Gap Analysis & Remediation Plan

Safeguard	Met	Partial	Gap
Administrative	5	2	5
Physical	0	1	0
Technical	1	4	1
HITRUST 01.m	0	1	0
HITRUST 07.a	1	0	0
HITRUST 01.q	0	0	1
Total	**7**	**8**	**7**

Key gaps and their risk

- **Logging and audit (A3, T3)** — no central log store or alerts: a misuse of PHI or an administrative change could go unnoticed. *High.* Addressed by Criterion 6.
- **Privileged access (A5)** — the only Owner is a guest personal account: no separation of duties and a single point of failure. *High.*
- **Credentials (H3)** — a shared registry admin password and storage keys exist and bypass identity controls. *Medium.*
- **Backup and DR (A9, A10)** — no recoverable copy of VM state. *Medium* in this lab (no PHI on the VM); *High* for production.
- **Network exposure (H1)** — the evidence storage account and registry accept traffic from any network (authentication still required). *Medium.*

Remediation plan

Pri.	Gap	Action	Target	Cost	Status
P1	H2	Tag all existing resources and resource groups to the CAN tagging standard (Cloud admin)	2026-10-08	$0	**Done**
P1	A5	Create a dedicated member admin account (not a guest), grant it Owner, and use it for administration; keep the personal account as break-glass (Cloud admin)	2026-10-12	$0	**Planned**
P1	T5	Confirm Entra Security Defaults (MFA for all users) is enabled; enable if not (Cloud admin)	2026-10-12	$0	**Planned**
P1	H3	Recreate aci-app-test with a managed identity + AcrPull, then disable the ACR admin user; disable shared-key access on cloudsecevidencecan (Cloud admin)	2026-10-15	$0	**Planned**
P1	H1	Restrict cloudsecevidencecan to selected networks; remove unused AzureBastionSubnet (Cloud admin)	2026-10-15	$0	**Planned**

Pri.	Gap	Action	Target	Cost	Status
P2	A3, T3	Export Activity Log and resource diagnostic logs to the Log Analytics workspace; create activity-log alerts for policy, NSG and role-assignment changes (SecOps)	Criterion 6	~$0 (5 GB free)	**Planned**
P2	A8	Write and test the cloud incident-response playbook (SecOps)	Criterion 6	$0	**Planned**
P2	A7	Stream Entra sign-in logs to Log Analytics for longer retention (requires P1 licence or diagnostic export) (SecOps)	Criterion 6	$0–licence	**Planned**
P3	A9, A10	Delete the temporary VM (removes the unbacked-up asset); for any production VM, enable Azure Backup (daily, 30-day retention) (Cloud admin)	2026-10-15	~$5/month per VM	**Planned**
P3	A6	Enable a VM vulnerability scanner (Defender for Servers P1 trial) for production hosts (SecOps)	Production	~$5/server/month	**Deferred (cost)**
P3	T2	Customer-managed keys (Key Vault) and encryption-at-host for PHI stores (Cloud admin)	Production	~$1–5/month	**Deferred (cost)**
P3	T6	Serve Keycloak over HTTPS with a trusted certificate behind a reverse proxy (App team)	Production	$0	**Deferred**
P3	T4	Enable blob soft-delete and versioning on stcanfunc9a8c964b (Cloud admin)	2026-10-15	<$0.01/month	**Planned**

*Priorities: **P1** free and immediate; **P2** delivered with Criterion 6 monitoring work; **P3** production hardening that carries cost and is deferred under the lab budget.*

Implementation Status

Implemented & verified: management-group hierarchy; organisation Deny guardrails (7 rules); mandatory tagging (6 rules) with all existing assets remediated; continuous HITRUST/HIPAA evaluation; HIPAA checklist of 22 controls with gap analysis and a 13-item remediation plan. Policy definitions and all test output are stored in `can-governance/`.

Issues Encountered

Issue	Resolution
Management Groups could not be listed (resource provider not registered)	Registered Microsoft.Management; created hierarchy and moved the subscription
HITRUST/HIPAA initiative includes deploy/modify policies that could create billable extensions	Assigned audit-only (DoNotEnforce); explicit Deny initiatives provide enforcement
Region test passed during the policy propagation window	Test resource deleted; re-test after propagation denied
West Europe refused by Azure capacity limits, not by policy	Discarded; re-tested with centralus

Issue	Resolution
'Subnets should have an NSG' flagged 5 subnets that do have NSGs	Verified association by CLI; treated as stale Defender assessment. Only AzureBastionSubnet (unused) truly lacks one — scheduled for removal
Defender for Containers plan found on Standard (free trial, 20 days left)	No clusters, so ~$0; added to plan: switch to Free before trial ends